

CYBER TABLETOP EXERCISE

SWIFT Workstation Compromise and Suspected Fraudulent Transfers

Facilitation-ready exercise | Executive, operational, payments, fraud,
legal/compliance and technical audiences

Recommended duration: 90 minutes

Classification: Internal use

Exercise mode: Discussion-based, no-fault learning

Scenario source: uploaded structured scenario and evaluation feedback. This revision strengthens the intrusion path, evidentiary detail, ATT&CK; mapping, success criteria, escalation logic and facilitator guidance.

1. Exercise Overview

This exercise simulates a financially motivated intrusion into a bank's SWIFT-connected treasury payment environment. The adversary obtains a valid remote-access account, reaches a hardened payments workstation, executes a lightweight PowerShell loader, suppresses selected endpoint telemetry, captures an operator's active session, and uses that trusted context to create and release fraudulent cross-border payment messages.

Participants must contain payment fraud risk without causing uncontrolled settlement disruption, determine which messages are legitimate, coordinate urgent holds and recalls, preserve evidence, manage executive and regulatory escalation, and define defensible restoration criteria.

Exercise design improvements

- A precise, internally consistent attack chain replaces speculative compromise language.
- Each inject introduces decision-relevant evidence, not merely narrative escalation.
- Technical containment, fraud recovery, business continuity and crisis governance are explicitly separated.
- Success criteria and observer scoring are included for measurable learning outcomes.
- MITRE ATT&CK; mappings are tied directly to stated scenario facts.

Exercise objectives

- Identify and suppress suspicious SWIFT activity before additional release.
- Validate authority to isolate high-trust endpoints, disable accounts and pause payment flows.
- Test joint decision-making among SOC, treasury, fraud, legal/compliance and executives.
- Exercise urgent correspondent-bank hold and recall procedures.
- Demonstrate evidence preservation, incident chronology and safe-reconnection governance.
- Assess whether priority legitimate payments can continue under enhanced manual controls.

Scope

In scope	Out of scope
SWIFT workstation, gateway, payment queue, operator identities, approval workflow, interbank recall, crisis escalation, continuity and recovery.	Deep malware reverse engineering, product-specific SWIFT administration, jurisdiction-specific legal advice, and live contact with external institutions.

2. Participants, Governance and Rules

Core roles

Incident Commander / Cyber Lead	Owns cyber incident declaration, technical containment coordination and consolidated situation reporting.
SOC / DFIR	Validates alerts, scopes access, isolates assets, revokes credentials and preserves evidence.
Treasury / Payment Operations	Stops release, validates transactions, manages liquidity and defines priority-payment continuity.
Fraud / Financial Crime	Classifies transactions, leads beneficiary/correspondent outreach and tracks hold/recall outcomes.
Legal / Compliance / Privacy	Advises on notification, privilege, recordkeeping, regulatory and contractual obligations.
Executive Crisis Lead	Resolves cross-business risk trade-offs and approves material continuity or restoration decisions.
Communications / Relationship Owners	Coordinates approved internal, client, correspondent and media messaging.
Facilitator / Scribe / Observers	Control exercise flow, record decisions, score performance and capture actions.

Governance principles

- SOC may immediately isolate a demonstrably compromised endpoint or identity under pre-authorized emergency authority.
- Treasury owns payment legitimacy and operational prioritization; fraud owns recall coordination.
- The executive crisis lead approves broad payment suspension, material residual risk acceptance and restoration after assurance criteria are met.
- Legal/compliance advises; it does not replace operational or cyber ownership.

Rules of engagement

- Treat all injects as real unless the facilitator states otherwise.
- Respond using current authorities, processes and tools; identify workarounds rather than inventing capabilities.
- State assumptions clearly and record unresolved dependencies.
- Real incidents take priority. The exercise is no-fault and learning-focused.
- Do not fight the scenario; challenge decisions, not the premise.

3. Scenario Narrative and Confirmed Intrusion Path

The bank operates a segregated SWIFT payment environment with dual approval, privileged administration and centrally monitored Windows endpoints. A third-party support account used for after-hours maintenance was not disabled after a contractor rotation. The account remained protected by password-only VPN authentication because its token exception had not expired in the access register.

1. Initial access	The actor authenticates to the remote-access service with the dormant support account from an unusual geography. The login is allowed because the account is valid and the source is not blocked.
2. Remote access	Using the authorized support path, the actor reaches a jump host and then the SWIFT-connected workstation permitted by the account's legacy access group.
3. Execution	The actor launches PowerShell from the workstation to retrieve and execute a small in-memory utility from an attacker-controlled HTTPS site.
4. Defense evasion	The utility stops the endpoint logging agent for 11 minutes and clears selected PowerShell operational logs. Network logs remain available.
5. Credential/session abuse	The actor captures an unlocked treasury operator session and reuses its active application context. No domain administrator compromise is required.
6. Discovery	The actor reviews recent beneficiary templates, message history, cutoff windows and approval patterns to make transactions appear plausible.
7. Fraud action	Three fraudulent cross-border messages are created. Two remain queued; one is released after the actor reuses an already-approved beneficiary template and an active approver session.
8. Detection	Treasury notices abnormal timing and beneficiary combinations while SOC receives an alert for the remote login and telemetry interruption.

Facilitator control: The above path is authoritative. Participants may investigate alternatives, but the facilitator should not introduce unsupported malware, lateral movement or data exfiltration.

4. Exercise Timeline at a Glance

Time	Inject	Primary pressure	Required decision
08:30	1 - Unusual messages	Ambiguous queue activity	Declare incident, stop release, preserve evidence
09:00	2 - Compromise evidence	Confirmed remote access and telemetry gap	Contain endpoint/account and choose payment freeze scope
09:45	3 - Released payment	Narrow recall window	Launch hold/recall and brief executives
11:00	4 - Continuity conflict	Priority settlements accumulating	Authorize controlled manual processing or maintain freeze
15:00	5 - Recovery request	Business pressure to reconnect	Apply restoration gates and risk sign-off
Next day	6 - Aftermath	Recall uncertain; notification questions	Govern post-incident actions and remediation

Recommended facilitation cadence

- 10 minutes - objectives, roles and rules.
- 60 minutes - six inject discussions, approximately 8-12 minutes each.
- 10 minutes - cross-inject decision review.
- 10 minutes - debrief, confidence scoring and action assignment.

5. Inject 1 - Unusual Messages Queued

Simulated time: 08:30 Stage: Detection and triage

Primary objective: Recognize suspected payment fraud and establish cross-functional command.

Scenario narrative

Treasury operations identifies three unusual cross-border messages created between 02:48 and 03:06 from a SWIFT-connected workstation. Two are still queued. One message status is unclear because the local queue and gateway display have not yet synchronized.

Information provided to participants

- Two beneficiaries are new; one beneficiary is a recently used supplier but the amount is 8x the normal range.
- The workstation owner states they were not working overnight.
- A ServiceNow incident exists, but no cyber incident has been declared.
- The next payment cutoff is in 45 minutes.

Discussion questions

- Who declares the incident and at what severity?
- Who can stop approval or transmission immediately?
- Which evidence must be preserved before isolation?
- How will treasury validate legitimacy without relying on the potentially compromised workstation?
- Which stakeholders must be notified now, and which can wait?

Expected actions

- Declare a cyber-enabled fraud incident and appoint an incident commander.
- Freeze the suspicious messages and prevent new release from the affected workstation.
- Begin joint SOC, treasury and fraud review.
- Preserve queue, gateway, workstation, identity, VPN and approval logs.
- Open a decision log and payment-status register.

Facilitator notes

Do not allow the discussion to become a generic malware investigation. Press for an immediate payment-control action, named decision owners and a timestamped source of truth.

Suggested artifact

Queue screenshot, payment list, operator statement and initial SOC alert.

6. Inject 2 - Confirmed Compromise Evidence

Simulated time: 09:00 Stage: Containment

Primary objective: Choose containment scope using concrete evidence.

Scenario narrative

SOC correlates a valid VPN login by a dormant support account, an RDP session to the SWIFT workstation and an 11-minute endpoint telemetry interruption. PowerShell execution is confirmed. The workstation remains online because operations wants to preserve the current queue state.

Information provided to participants

- VPN source country is inconsistent with the account owner's location.
- The support account can access the SWIFT workstation through a legacy group.
- PowerShell connected to an external HTTPS destination.
- No evidence currently shows compromise of the central SWIFT gateway.
- One legitimate high-value settlement is approaching cutoff.

Discussion questions

- Isolate only the workstation, or also the gateway and broader payment path?
- Which identities and sessions must be disabled?
- What evidence supports or opposes a full payment freeze?
- Can the legitimate settlement proceed under an alternate trusted path?
- Who accepts residual risk if limited operations continue?

Expected actions

- Isolate the workstation and revoke the support account and related sessions.
- Block the observed external destination and preserve volatile evidence where feasible.
- Apply a temporary release freeze until queued messages are independently validated.
- Establish enhanced dual control for any exception payment.
- Escalate the continuity decision to treasury leadership and the executive crisis lead.

Facilitator notes

A broad shutdown is not automatically correct. Reward participants who distinguish confirmed compromise from unproven gateway impact and who use compensating controls for essential payments.

Suggested artifact

VPN event, RDP log, EDR health gap, PowerShell network event and access-group membership.

7. Inject 3 - One Message Was Released

Simulated time: 09:45 Stage: Fraud response and external coordination

Primary objective: Exercise time-critical hold and recall actions.

Scenario narrative

The gateway confirms that one suspicious payment was transmitted 18 minutes before the freeze. It is awaiting downstream processing at a correspondent institution. Fraud estimates that a hold request submitted within the next 20 minutes has a meaningful chance of success.

Information provided to participants

- Amount: USD 7.8 million.
- The intermediary and beneficiary banks are known.
- Originator details and approval history are available in the message archive.
- Executives request a quantified exposure and recommendation within 15 minutes.

Discussion questions

- Who owns the recall request and who is authorized to attest fraud?
- What information can be sent immediately, and what requires legal review?
- Which channels are used if normal relationship contacts do not respond?
- When are law enforcement, insurers or regulators considered?
- How will updates be synchronized across cyber, fraud and executive teams?

Expected actions

- Launch urgent correspondent hold/recall outreach using pre-approved channels.
- Create a single status record for the payment, timestamps and contacts.
- Provide executives with best case, likely case and worst case exposure.
- Preserve all communications and decision evidence.
- Continue review for other messages, beneficiary changes and approval misuse.

Facilitator notes

Make participants separate technical containment from financial recovery. The SOC should support facts; fraud or payments relationship owners should lead recall.

Suggested artifact

Released-message details, call tree, recall form and executive briefing template.

8. Inject 4 - Continuity Under Pressure

Simulated time: 11:00 Stage: Business continuity

Primary objective: Test controlled payment continuation during active investigation.

Scenario narrative

Six legitimate payments are now delayed. Two affect same-day liquidity obligations. Treasury proposes rebuilding them on a clean standby workstation, with call-back verification and three-person approval. SOC cannot yet guarantee that the gateway is unaffected, but has found no gateway indicators.

Information provided to participants

- The standby workstation was last tested 45 days ago.
- Approver tokens are available, but one approver is remote.
- Manual processing will reduce throughput by approximately 70%.
- The released fraudulent payment remains under review by the correspondent.

Discussion questions

- What minimum safeguards are required to process priority payments?
- Who selects which payments are truly critical?
- Is the standby workstation sufficiently trusted?
- What additional monitoring and reconciliation are required?
- Who documents and accepts residual risk?

Expected actions

- Prioritize payments using defined liquidity and client-impact criteria.
- Validate the standby workstation, identities and message path before use.
- Apply independent call-back, three-person approval and post-transmission confirmation.
- Increase monitoring and reconcile every manually released message.
- Record executive approval and time-bound the exception process.

Facilitator notes

Challenge vague claims that a payment is 'critical.' Require criteria, named owners, an expiry time and rollback conditions.

Suggested artifact

Priority-payment list, standby validation checklist and exception-risk form.

9. Inject 5 - Recovery and Safe Restoration

Simulated time: 15:00 Stage: Recovery

Primary objective: Define measurable restoration gates.

Scenario narrative

The compromised workstation has been removed. The support account is disabled, the legacy access group is corrected, and a clean replacement workstation is available. No further suspicious messages are identified. Business leadership requests normal service restoration before the next regional opening.

Information provided to participants

- Forensic review confirms PowerShell execution and telemetry tampering on one workstation only.
- Gateway integrity checks are clean and message reconciliation is complete.
- All operator and support credentials in scope have been reset or revalidated.
- The recall outcome remains pending.

Discussion questions

- What evidence is required before reconnecting?
- Who signs off from cyber, treasury and executive leadership?
- What residual risks remain even if the fraud recall is unresolved?
- What heightened monitoring is required and for how long?
- What conditions trigger immediate re-isolation?

Expected actions

- Complete documented technical, identity, payment and reconciliation gates.
- Obtain joint SOC and treasury readiness confirmation plus executive risk approval.
- Enable enhanced logging, session monitoring and transaction anomaly review.
- Define rollback thresholds and 24/48/72-hour review points.
- Keep fraud recovery workstream active independently of system restoration.

Facilitator notes

Do not let 'vendor says safe' or 'malware removed' become the sole restoration criterion. Restoration must address identity, message integrity, business reconciliation and monitoring.

Suggested artifact

Restoration decision record, control checklist and residual-risk statement.

10. Inject 6 - Next-Day Governance

Simulated time: Next business day Stage: Post-incident obligations

Primary objective: Test reporting, remediation ownership and lessons learned.

Scenario narrative

The correspondent has frozen the USD 7.8 million payment but requests formal documentation. The regulator asks whether the incident affected payment integrity, client assets or the bank's ability to deliver critical services. Internal audit requests the decision log and evidence that emergency access has been remediated.

Information provided to participants

- No additional fraudulent messages were released.
- The bank experienced a four-hour controlled payment slowdown.
- The dormant support-account exception had expired but was not removed.
- Several manual continuity steps were undocumented.

Discussion questions

- Who owns the regulatory narrative and factual validation?
- What is reportable now versus after further confirmation?
- How are control failures assigned without losing accountability?
- Which remediation actions require executive tracking?
- What should be retested in the next exercise?

Expected actions

- Produce a fact-based incident chronology and impact assessment.
- Complete required legal, regulatory, insurer and counterparty notifications.
- Assign remediation owners and deadlines for identity governance, access reviews, endpoint telemetry and payment continuity.
- Conduct a lessons-learned session separate from personnel accountability.
- Schedule validation testing and a follow-up exercise.

Facilitator notes

Probe for defensible evidence, not optimistic statements. The exercise ends only when actions have owners, dates and verification methods.

Suggested artifact

Regulatory fact sheet, after-action report and remediation tracker.

11. Evaluation Framework and Success Criteria

Domain	Successful performance	Warning signs
Detection & command	Incident declared within 10 exercise minutes; incident commander, cyber lead and payment owner named.	Teams debate ownership; no shared chronology or severity rationale.
Payment control	Suspicious queue frozen promptly; every message assigned a verified status.	Reliance on compromised workstation; queue status remains ambiguous.
Containment	Affected endpoint and identities isolated based on evidence; gateway decision documented.	Unbounded shutdown or failure to revoke sessions/accounts.
Fraud recovery	Recall launched within the inject's 20-minute window; counterpart outreach owner clear.	SOC expected to own interbank recall; legal review blocks urgent action.
Continuity	Priority criteria, compensating controls, expiry and risk owner documented.	Ad hoc exceptions; 'critical' payments not objectively prioritized.
Recovery	Technical, identity, payment and monitoring gates completed before restoration.	Restoration based only on elapsed time or leadership pressure.
Governance	Regulatory facts, decisions, assumptions and residual risks are auditable.	Conflicting external statements or undocumented risk acceptance.

Observer confidence scale

- 1 - Not at all confident
- 2 - Slightly confident
- 3 - Somewhat confident
- 4 - Fairly confident
- 5 - Completely confident

Observers should record one evidence-based strength, one gap, and one action for each domain. Scores are discussion aids, not performance rankings.

12. MITRE ATT&CK; Mapping

The mapping below is restricted to behaviors explicitly stated in the scenario. It intentionally avoids unsupported persistence, privilege escalation, malware-family or broad lateral-movement claims.

Stage	Tactic	Technique / sub-technique	Scenario evidence
Initial access	Initial Access / Defense Evasion	T1078 - Valid Accounts	Dormant third-party support account authenticates successfully to remote access.
Remote reach	Lateral Movement	T1021.001 - Remote Services: RDP	The actor uses an authorized jump path and RDP to reach the SWIFT workstation.
Execution	Execution	T1059.001 - PowerShell	PowerShell retrieves and executes an in-memory utility.
Defense evasion	Defense Evasion	T1562.001 - Impair Defenses: Disable or Modify Tools	Endpoint telemetry is stopped for 11 minutes.
Log tampering	Defense Evasion	T1070.001 - Clear Windows Event Logs	Selected PowerShell operational logs are cleared.
Discovery	Discovery	T1087 / T1018 / payment-application discovery context	The actor reviews accessible identities, systems and payment history to understand workflow. Facilitators should only use sub-techniques supported by evidence presented in play.
Session abuse	Credential Access / Defense Evasion	T1550 - Use Alternate Authentication Material (scenario-aligned session reuse)	The actor reuses an active authenticated application context rather than obtaining a new approval credential.
Fraud objective	Impact	T1657 - Financial Theft	Fraudulent payment messages are created and one is released.

Facilitator note: If participants hypothesize credential dumping, persistence or additional lateral movement, treat those as investigative hypotheses until an inject provides supporting evidence. The strongest direct mappings are Valid Accounts, RDP, PowerShell, Impair Defenses, Clear Windows Event Logs and Financial Theft.

13. Debrief, Lessons Learned and Action Tracking

Closing discussion prompts

- At what point did the organization recognize a cyber-enabled fraud event rather than an IT issue?
- Were cyber containment and payment-fraud recovery responsibilities correctly separated?
- Could the organization determine the status of every queued and transmitted message?
- Were emergency access, dormant accounts and legacy access groups governed effectively?
- Could priority payments continue under controls that were specific, auditable and time-limited?
- Were restoration criteria objective enough to withstand business pressure?
- Which external communications could be issued immediately from pre-approved templates?

Required after-action outputs

Output	Minimum content	Owner / due date
Decision log	Timestamp, decision, options, evidence, approver, residual risk	Assign during debrief
Incident timeline	Identity, endpoint, network, payment and external-contact events	Assign during debrief
Gap register	Control/process gap, impact, root cause, interim mitigation	Assign during debrief
Action plan	Owner, deadline, validation method, dependency, status	Assign during debrief
Exercise report	Objectives, observations, scores, lessons and management response	Within agreed governance cycle

Priority remediation themes

- Remove expired remote-access exceptions and require phishing-resistant MFA for all privileged support paths.
- Review segmentation and jump-host entitlements for high-trust payment environments.
- Alert on endpoint telemetry interruption, unusual PowerShell use and after-hours access to payment assets.
- Strengthen queue reconciliation, beneficiary anomaly detection and independent release verification.
- Pre-stage correspondent hold/recall templates, call trees and alternate contacts.
- Test standby payment workstations and manual continuity procedures on a defined schedule.

14. Facilitator Quick Reference

Inject	Desired decision	Escalation cue if discussion stalls
1	Freeze suspicious messages and establish command.	A fourth message appears in draft status.
2	Isolate endpoint/account; decide gateway scope.	Telemetry gap expands by five minutes.
3	Launch hold/recall immediately.	Correspondent says the payment may settle in 12 minutes.
4	Authorize or reject controlled priority processing.	Liquidity team warns of a same-day obligation.
5	Apply restoration gates and joint sign-off.	Leadership asks to reconnect before regional opening.
6	Produce factual reporting and owned remediation.	Regulator requests a written response by end of day.

End-state statement

The exercise is complete when participants can explain, with named owners and recorded evidence, how the bank stopped further fraudulent release, pursued recovery of the transmitted payment, maintained critical services under controlled exceptions, restored the environment safely, and converted identified gaps into verified remediation actions.